

Lab 3 - Phishing Email Investigation

Safe Simulated Email Analysis and IOC Extraction

Lab Type	SOC / Email Security Investigation
Scenario	Simulated phishing email
Environment	Windows 11 VM / text-based analysis
Objective	Identify phishing indicators, extract IOCs, and document findings

1. Objective

The objective of this lab was to investigate a safe, simulated phishing email using a SOC analyst workflow. The analysis focused on sender anomalies, social-engineering indicators, suspicious links, email authentication results, IOC extraction, MITRE ATT&CK; mapping, and a final analyst conclusion.

2. Simulated Email

From: Microsoft 365 Security <security-alert@micrs0ft-support.example>

To: employee@example.com

Subject: URGENT: Your Microsoft 365 account will be suspended

Reply-To: account-verification@secure-mail.example

The message claimed that unusual activity had been detected and that the account would be suspended within 24 hours unless the user verified their identity through a supplied link.

Safety note: All domains and IP addresses in this lab are simulated training data. The **.example** domain space and **203.0.113.50** documentation address were used to avoid interacting with real infrastructure.

3. Sender and Header Analysis

Indicator	Observed value	Interpretation
Display name	Microsoft 365 Security	Attempts to appear legitimate
From address	security-alert@micrs0ft-support.example	Lookalike spelling uses 0 in place of o
Reply-To	account-verification@secure-mail.example	Different domain from visible sender
Return-Path	account-verification@secure-mail.example	Does not align with visible sender
Received IP	203.0.113.50	Documentation/test address
SPF	fail	Sending server not authorized
DKIM	none	No DKIM signature present
DMARC	fail	Authentication/alignment requirements not satisfied

4. Social Engineering Indicators

The email used urgency, a generic greeting, threats of account suspension, a demand for immediate verification, and a warning of permanent account loss. These techniques are designed to pressure a recipient into acting quickly without independent verification.

5. URL Analysis

The message contained **https://login-microsoft.example/verify**. The protocol was HTTPS, the host was **login-microsoft.example**, and the path was **/verify**. HTTPS alone does not make a site trustworthy.

6. Indicators of Compromise (IOCs)

IOC Type	Value
Sender email	security-alert@micrs0ft-support.example
Reply-To email	account-verification@secure-mail.example
URL	https://login-microsoft.example/verify
Received IP (simulated)	203.0.113.50

7. MITRE ATT&CK; Mapping

T1566.002 - Phishing: Spearphishing Link

The email attempted to direct the recipient to a suspicious verification link. The likely objective was credential theft, but there was no evidence that credentials were actually submitted or stolen.

8. Investigation Timeline

Step	Finding
1	Suspicious email received for analysis
2	Sender and Reply-To mismatch identified
3	Lookalike sender spelling identified
4	Urgency and account-suspension language identified
5	Suspicious verification URL analyzed
6	SPF fail, DKIM none, and DMARC fail reviewed
7	IOCs extracted and ATT&CK technique mapped

9. Findings

The message contained multiple indicators consistent with phishing: a lookalike sender domain, From/Reply-To mismatch, high-pressure language, a suspicious verification URL, SPF and DMARC failures, and no DKIM signature.

The likely objective was credential theft. However, no evidence was observed that the link was clicked, credentials were submitted, malware executed, or an account compromised.

10. Recommended SOC Response

Action	Purpose
Quarantine/remove the message	Prevent additional user interaction
Block sender/domain/URL indicators	Reduce repeat delivery and access
Search for similar messages	Determine whether other users were targeted
Check link-click and sign-in telemetry	Look for user interaction or credential use
Document/escalate if compromise evidence supports incident response	

11. Conclusion

The simulated email was assessed as a phishing attempt based on multiple independent indicators. The lab demonstrated a practical SOC email-triage workflow including sender validation, header analysis, URL review, IOC extraction, authentication-result interpretation, MITRE ATT&CK; mapping, and evidence-based reporting.

Portfolio summary: Investigated a simulated phishing email, identified lookalike-domain and sender inconsistencies, analyzed SPF/DKIM/DMARC results, extracted IOCs, mapped the activity to MITRE ATT&CK; T1566.002, and documented a SOC response.